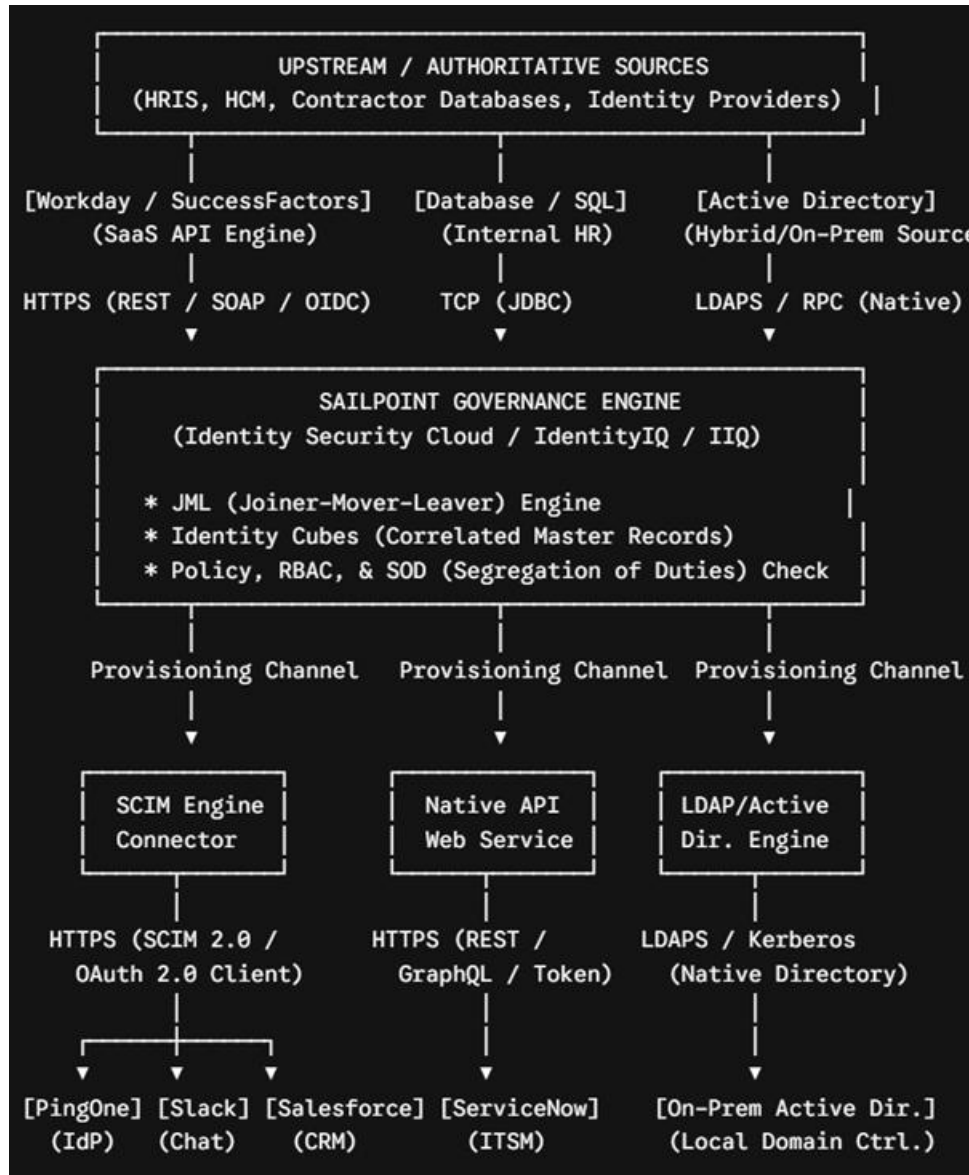
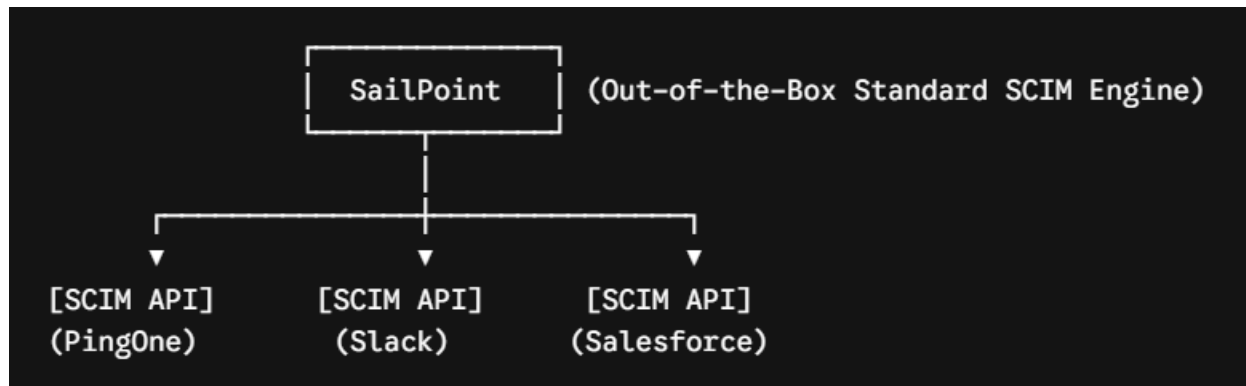


SCIM (System for Cross-domain Identity Management) is an open **IETF** (Internet Engineering Task Force) **standard** that follow and combine different RFC **specification and is a universal translator for identity data**. It is an open standard designed to automate user provisioning and let different systems (like an HR tool and an Identity Provider) talk to each other seamlessly, using SCIM APIs.

End to End Platform integration





SCIM Spec: Core philosophy is “An identity is an identity, no matter where it lives”

SCIM provides a **strict, predictable contract**. It relies entirely on two open building blocks

1. **JSON Object Models** for representing users and groups.
2. **Standard RESTful HTTP Web Services** for moving those objects.

RFC 7643 (SCIM Core Schema), the object models are divided cleanly based on their specification source and namespace isolation

A. SCIM Standard Data

This represents the out-of-the-box, universally recognized attributes that any SCIM-compatible platform must implement without modification.

- **Core Resource Types:** Defines the foundational objects—primarily /Users and /Groups.
- **The Baseline Blueprint (urn:ietf:params:scim:schemas:core:2.0:User):** Dictates standard primitives (userName, active) and complex multi-valued objects (emails, phoneNumbers) that carry rigid, predefined data types (e.g., Boolean, DateTime, String).
- **Standard Enterprise Extension (urn:ietf:params:scim:schemas:extension:enterprise:2.0:User):** A pre-defined structural extension built into the RFC to standardize corporate-specific metadata (employeeNumber, costCenter, department, and manager reference pointers).

B. SCIM Custom Data (Schema Extensions)

When an enterprise needs to synchronize identity data that falls outside the standard spec, they utilize **Schema Extensions**.

- **Namespace Isolation (URNs):** Custom attributes cannot simply be injected loosely into the root JSON object. They must be grouped inside a custom, site-specific Uniform Resource Name namespace (e.g., `urn:ietf:params:scim:schemas:extension:yourcompany:2.0:User`).
- **Type Compliance:** Even though the attribute is custom (e.g., `securityClearance`), it must strictly utilize the native SCIM primitive data types (String, Boolean, Integer, Decimal, DateTime, Binary, or Reference) defined in RFC 7643 Section 2.3.
- **Discovery Requirements:** Any platform supporting custom data must declare these extensions dynamically via the GET /Schemas metadata endpoint so client engines can auto-discover them.

Standard RESTful HTTP Web Services (The API & Protocol)

Under **RFC 7644 (SCIM Protocol)**, the API defines the explicit application-level behavior used to move and update those standard and custom schemas across domains.

A. Standard SCIM API Endpoints

The protocol requires a strict set of REST paths mapped directly to CRUD (Create, Read, Update, Delete) actions:

- POST /Users — Ingests a SCIM schema payload to provision an identity.
- GET /Users/{id} — Retrieves a specific identity profile wrapper.
- PUT /Users/{id} — Overwrites an entire schema model resource.
- PATCH /Users/{id} — Applies targeted add, remove, or replace mutations (PatchOp) to specific attributes without affecting the rest of the profile.
- DELETE /Users/{id} — Removes the resource from the target store.

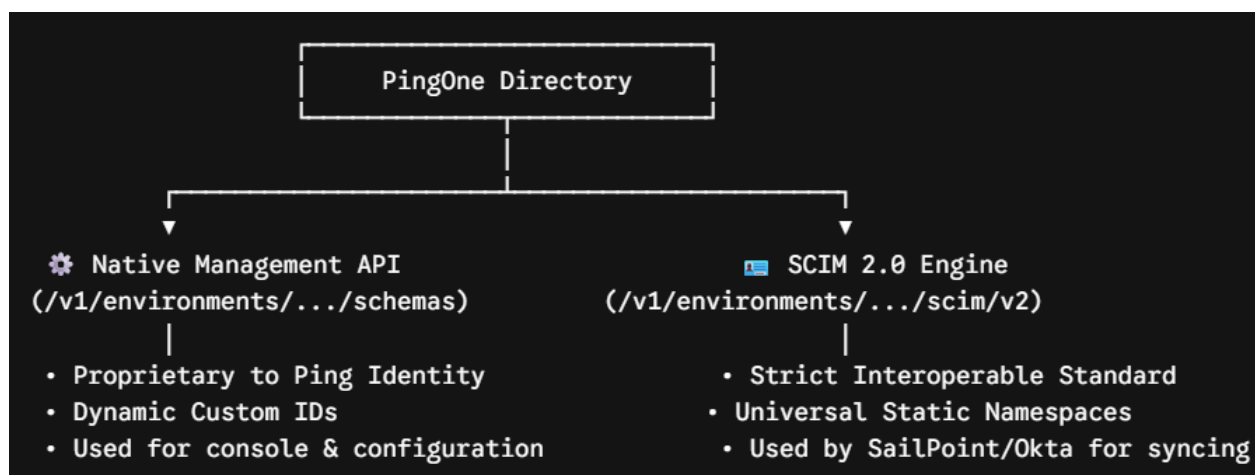
B. Advanced Protocol Mechanics

RFC 7644 goes beyond basic REST by standardizing how a platform handles complex, real-world directory operations:

- **The SCIM Filter Engine (?filter=):** Standardizes URL query parameters using attribute expressions (e.g., GET /Users?filter=username eq "jdoe@company.com"), requiring the platform backend to parse operators like eq (equal), co (contains), and sw (starts with).
- **Bulk Operations (/Bulk):** Allows a client to batch hundreds of lifecycle changes into a single HTTP payload request to minimize network overhead.
- **Service Discovery:** Exposes /ServiceProviderConfig, /ResourceTypes, and /Schemas so external governance engines can query exactly what features, endpoints, and attributes the platform supports before sending data.

PingOne platform exposes an Inbound SCIM 2.0 compliant REST gateway (RFC 7643/7644). This **allows** external Identity Governance platforms—specifically **SailPoint**—**to leverage their out-of-the-box standard provisioning engine, Universal SCIM Connector, to headlessly manage user directory lifecycle states (Joiners, Movers, Leavers) using standard protocol payloads,** removing the need for custom API development or manual administration."

PingOne: a cloud-native, multi-tenant Identity-as-a-Service (IDaaS) platform



PingOne has

- ❑ **The Core Directory:** It securely stores active workforce and customer identity profiles, credentials, and group memberships.
- ❑ **The Access Engine:** It handles single sign-on (SSO) portals, multi-factor authentication (MFA) prompts, federation protocols (OIDC, SAML), and dynamic access token distribution.

An integration between Identity Governance and Administration (IGA) platform (SailPoint) and Identity Provider (IdP) and directory engine (PingOne) is required to address following use cases

Use Case A: Birthright Provisioning (The Joiner)

- **Scenario:** A new software engineer is hired in the HR system.
- **Action:** SailPoint aggregates the HR file, detects the engineering job code, and automatically sends a POST request to PingOne's /Users endpoint.
- **Result:** The engineer is immediately created in the PingOne directory, mapped to the correct base Population, and can instantly log into the company SSO portal on day one.

Use Case B: Dynamic Access Changes (The Mover)

- **Scenario:** An employee transitions from Marketing to Finance.
- **Action:** SailPoint processes the role change and fires a PATCH request to PingOne to update their department attribute to "Finance" and dynamically swap their associated security group references.
- **Result:** The user immediately loses access to Marketing tools and gains access to the Finance dashboard via PingOne SSO.

Use Case C: Instant Offboarding (The Leaver)

- **Scenario:** An employee is terminated or leaves the company.
- **Action:** SailPoint triggers an immediate high-priority PATCH to PingOne, updating the attribute "active": false.
- **Result:** The user's status shifts to SUSPENDED instantly. All active PingOne SSO sessions are revoked, completely locking them out of corporate resources globally in seconds.

Use Case D: Periodic Access Certification (Audit & Compliance)

- **Scenario:** Security auditors require a quarterly review of who has "Domain Admin" access.
- **Action:** SailPoint pulls a list of all users and their group memberships from PingOne's SCIM /Users and /Groups endpoints.
- **Result:** SailPoint generates a clean dashboard for managers to approve or revoke access, keeping the enterprise legally and structurally compliant.

Demo , PingOne SCIM API

Detail:

SCIM (System for Cross-domain Identity Management) is an open **IETF** (Internet Engineering Task Force) **standard** that follow and combine different RFC **specification and is a universal translator for identity data**. It is an open standard designed to automate user provisioning and let different systems (like an HR tool and an Identity Provider) talk to each other seamlessly, using SCIM APIs.

At its core, the SCIM (System for Cross-domain Identity Management) 2.0 specification is a universal translator for identity data. It was designed to solve a massive industry headache: every cloud application historically had its own custom, proprietary REST API for creating, updating, and deleting user accounts.

Before SCIM, if you wanted to automate user management, you had to write custom code for every single application. SCIM eliminates this by standardizing both what the data looks like and how the data is moved.

The most common use case for SCIM is Automate internal employee lifecycles i.e. JML (Joiner, Mover, Leaver) automation but it has emerged to support multiple other business use cases like “B2B SaaS Sales”, “Mergers & Acquisitions” and “Partner/Vendor Federation”

Use Case 1: B2B SaaS Enterprise Onboarding (The "Enterprise Ready" Checkbox)

If your company builds a B2B Software-as-a-Service (SaaS) product and wants to sell to mid-market or enterprise clients, you are the Service Provider (SP). Your customers are the Identity Providers (IdP).

- **The Problem:** An enterprise customer buys 1,000 licenses of your software. Their IT admin does not want to manually create 1,000 accounts inside your application console, nor do they want their employees to have to wait for manual setup.
- **The SCIM Solution:** By exposing a standard SCIM inbound endpoint on your SaaS platform, your enterprise customers can connect their corporate IdP (like Okta, PingOne, or Entra ID) directly to your app. They control provisioning from their end, and your software automatically spawns accounts for their employees.
- **Why it Matters:** This is a major B2B procurement requirement. Supporting SCIM allows SaaS startups to close large enterprise deals by offering instant, secure customer onboarding.

Use Case 2: Mergers, Acquisitions, and Corporate Consolidation

When Company A acquires Company B, IT systems must be consolidated quickly.

- **The Problem:** Both companies have their own completely separate identity directories (e.g., Company A uses PingOne, Company B uses Okta). Migrating thousands of users manually or writing custom database extraction scripts is slow, highly prone to error, and insecure.
- **The SCIM Solution:** IT architectures use SCIM to set up a bridge. Company B's IdP is configured to run an outbound SCIM push directly into Company A's central PingOne directory.
- **Why it Matters:** This consolidates two entirely separate workforces into a single unified directory in days instead of months, ensuring that employees of the acquired company can immediately access shared resources.

Use Case 3: External Partner and Vendor Access Management (B2B2B)

Enterprises frequently work with external third-party agencies, consultants, vendors, or suppliers who need access to internal systems (like Jira, Slack, or proprietary apps) but *should not* be added as full-time employees in the core HR system.

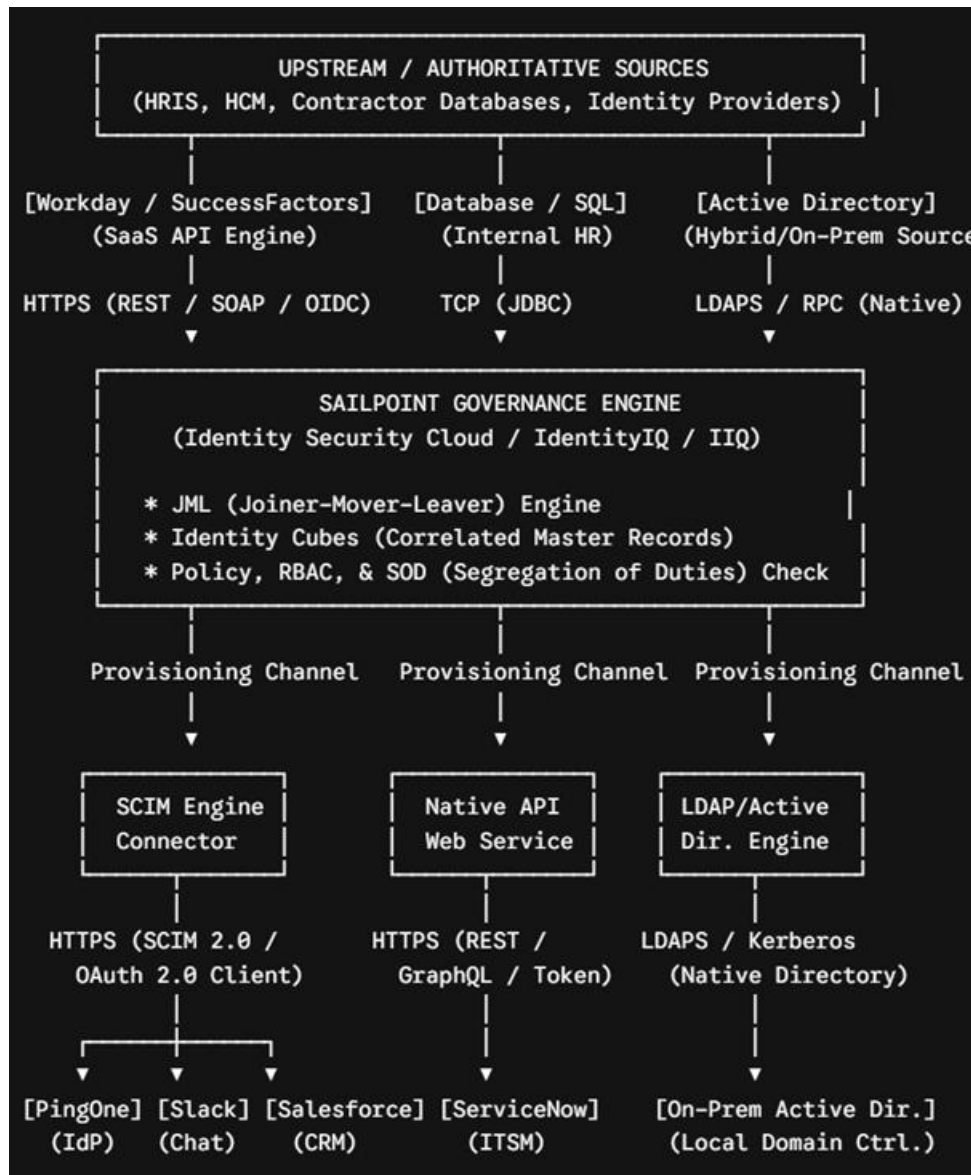
- **The Problem:** Managing the lifecycle of 500 external contractors from 10 different agency partners manually is an administrative nightmare. If a contractor leaves their agency, your IT department won't know, creating a massive security vulnerability (an "orphaned account").
- **The SCIM Solution:** The enterprise sets up a federated SCIM partnership. The external vendor's IT department manages their own users. When they disable a contractor in *their* system, their outbound SCIM engine automatically fires a deactivation API call to the enterprise's target systems.
- **Why it Matters:** It offloads the administrative burden of contractor lifecycle management back to the partner company while maintaining absolute, automated security.

Use Case 4: Synchronizing the Corporate Org Chart (Group & Directory Sync)

SCIM is not just about users—it is also highly optimized for Group Synchronization via /Groups.

- **The Problem:** SaaS platforms need to know who reports to whom and what department teams exist to enforce collaboration boundaries (e.g., ensuring only the "HR Team" group can see performance review folders in a document management app).
- **The SCIM Solution:** SCIM syncs the actual nested directory structure. When a "Marketing" group is updated with new sub-departments in PingOne, the SCIM engine synchronizes both the users and the structural hierarchy to downstream applications.
- **Why it Matters:** It maintains consistent, role-based access control (RBAC) across dozens of disjointed SaaS applications simultaneously without manual configuration in each tool.

End to End Platform integration



Detailed Breakdown of the Lifecycle Flow

Step 1: Upstream Ingestion (The "Joiner" Phase)

The lifecycle begins when HR hires an employee or sponsors a contractor.

- **Upstream Platforms:** Workday, SAP SuccessFactors, local database/SQL tables, or directory services.
- **Protocol Used:**
 - **REST/SOAP/GraphQL (over HTTPS):** For cloud-native SaaS like Workday or SuccessFactors.

- JDBC (Java Database Connectivity): Directly querying internal relational databases.
- LDAPS (LDAP over SSL): Secure directory queries if an existing Active Directory acts as the contractor/partner source.
- The Action: SailPoint runs a scheduled Aggregation Task (using read-only service accounts) to ingest user records.

Step 2: Correlation & Policy Processing (Inside SailPoint)

Once the data reaches SailPoint, the system doesn't immediately push it out. It runs it through a processing pipeline:

1. Identity Cube Creation: Maps raw attributes (Name, Title, Department, Manager ID) to a unified identity profile.
2. Manager Correlation: Builds the organizational reporting structure automatically.
3. Policy Evaluation: Checks if the user's role grants them automated access (Birthright Provisioning) or flags any Segregation of Duties (SoD) violations (e.g., a user cannot have both "Create Invoice" and "Approve Invoice" access).

Step 3: Downstream Provisioning (The "Mover / Leaver" Phase)

Once access is determined, SailPoint initiates provisioning out to target applications. Depending on the target system's capabilities, SailPoint dynamically routes the payload through one of several connector engines:

Engine A: Out-of-the-Box SCIM Engine (PingOne, Slack, Salesforce)

Used for modern SaaS applications built to understand the SCIM (System for Cross-Domain Identity Management) standard.

- Protocol: SCIM 2.0 JSON Payload over HTTPS.
- Authentication: OAuth 2.0 (Client Credentials grant type) or Bearer Token.
- Downstream Targets:
 - PingOne: Instantly creates the identity so the user can log in via Single Sign-On (SSO).
 - Slack: Provisions the account and places the user into standard default workspaces/channels.
 - Salesforce: Creates the user account and assigns baseline licenses.

Engine B: Web Services / Native API Connector (ServiceNow, Jira)

Used for target systems that do not native support SCIM but do offer robust custom APIs.

- **Protocol:** Custom JSON/XML REST or SOAP API requests over HTTPS.
- **Authentication:** Basic Auth, API Key, or custom OAuth flows.
- **Downstream Target:** ServiceNow (Provisions IT Service Management accounts or generates access tickets for manual completion).

Engine C: Native Directory Connector (Active Directory, Azure AD/Entra ID)

Used for legacy, on-premises, or hybrid directory systems where SCIM or standard APIs are not used.

- **Protocol:** Native RPC, LDAPS, or Microsoft Graph API (for Entra ID).
- **Downstream Target:** Active Directory / Entra ID (Builds the primary Windows OS login, assigns O365 licenses, and registers security groups).

SCIM Spec: Core philosophy is “An identity is an identity, no matter where it lives”

The specification is officially defined by the IETF across three core documents, **RFC 7642**, **RFC 7643** and **RFC 7644**

SCIM provides a **strict, predictable contract**. It relies entirely on two open building blocks

1. **JSON Object Models** for representing users and groups.
2. **Standard RESTful HTTP Web Services** for moving those objects.

Under **RFC 7643 (The Schema)** It define the core standard contract

- a. **Predefined Resource Types:** "User" and "Group" are the default, out-of-the-box Resource Types.
- b. **Core Schemas:** They map to strict, standard schemas identified by unique, globally recognized URNs (Uniform Resource Names):
 - **User Schema:** urn:ietf:params:scim:schemas:core:2.0:User
 - **Group Schema:** urn:ietf:params:scim:schemas:core:2.0:Group

Apart from Users and Groups, the SCIM specification defines several other structural and metadata objects

Enterprise User Extension:

While not a standalone object, this is a predefined *extension schema* defined in RFC 7643. It extends the core User object to cleanly house corporate attributes like employeeNumber, costCenter, organization, division, department, and manager and recognized using URN (Uniform Resource Names) **urn:ietf:params:scim:schemas:extension:enterprise:2.0:User**

The specification is officially defined by the IETF across three core documents:

- **RFC 7642 (Concepts):** Defines the scenarios, definitions, and business logic.
- **RFC 7643 (The Schema):** The strict structural data blueprint. It defines exactly what fields exist (e.g., userName, emails, name.familyName) and their data types.
- **RFC 7644 (The Protocol):** The explicit REST endpoints, query parameter filtering syntax, and HTTP status codes used to manage those schemas.

RFC 7643 (SCIM Core Schema), the object models are divided cleanly based on their specification source and namespace isolation

A. SCIM Standard Data

This represents the out-of-the-box, universally recognized attributes that any SCIM-compatible platform must implement without modification.

- **Core Resource Types:** Defines the foundational objects—primarily /Users and /Groups.
- **The Baseline Blueprint (urn:ietf:params:scim:schemas:core:2.0:User):** Dictates standard primitives (userName, active) and complex multi-valued objects (emails, phoneNumbers) that carry rigid, predefined data types (e.g., Boolean, DateTime, String).
- **Standard Enterprise Extension (urn:ietf:params:scim:schemas:extension:enterprise:2.0:User):** A pre-defined structural

extension built into the RFC to standardize corporate-specific metadata (employeeNumber, costCenter, department, and manager reference pointers).

B. SCIM Custom Data (Schema Extensions)

When an enterprise needs to synchronize identity data that falls outside the standard spec, they utilize **Schema Extensions**.

- **Namespace Isolation (URNs):** Custom attributes cannot simply be injected loosely into the root JSON object. They must be grouped inside a custom, site-specific Uniform Resource Name namespace (e.g., urn:ietf:params:scim:schemas:extension:yourcompany:2.0:User).
- **Type Compliance:** Even though the attribute is custom (e.g., securityClearance), it must strictly utilize the native SCIM primitive data types (String, Boolean, Integer, Decimal, DateTime, Binary, or Reference) defined in RFC 7643 Section 2.3.
- **Discovery Requirements:** Any platform supporting custom data must declare these extensions dynamically via the GET /Schemas metadata endpoint so client engines can auto-discover them.

Standard RESTful HTTP Web Services (The API & Protocol)

Under **RFC 7644 (SCIM Protocol)**, the API defines the explicit application-level behavior used to move and update those standard and custom schemas across domains.

A. Standard SCIM API Endpoints

The protocol requires a strict set of REST paths mapped directly to CRUD (Create, Read, Update, Delete) actions:

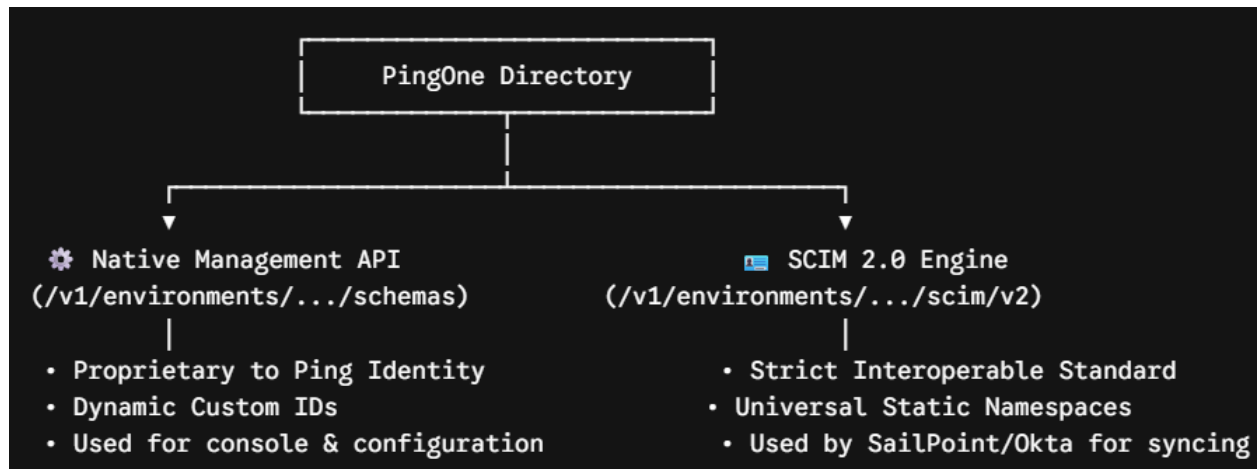
- POST /Users — Ingests a SCIM schema payload to provision an identity.
- GET /Users/{id} — Retrieves a specific identity profile wrapper.
- PUT /Users/{id} — Overwrites an entire schema model resource.
- PATCH /Users/{id} — Applies targeted add, remove, or replace mutations (PatchOp) to specific attributes without affecting the rest of the profile.
- DELETE /Users/{id} — Removes the resource from the target store.

B. Advanced Protocol Mechanics

RFC 7644 goes beyond basic REST by standardizing how a platform handles complex, real-world directory operations:

- **The SCIM Filter Engine (?filter=):** Standardizes URL query parameters using attribute expressions (e.g., GET /Users?filter=username eq "jdoe@company.com"), requiring the platform backend to parse operators like eq (equal), co (contains), and sw (starts with).
- **Bulk Operations (/Bulk):** Allows a client to batch hundreds of lifecycle changes into a single HTTP payload request to minimize network overhead.
- **Service Discovery:** Exposes /ServiceProviderConfig, /ResourceTypes, and /Schemas so external governance engines can query exactly what features, endpoints, and attributes the platform supports before sending data.

PingOne



1. The Native Platform API (.../v1/.../schemas)

- **What it is:** PingOne's proprietary, vendor-specific API engine.
- **The Response:** It returns data structures formatted using Ping Identity's internal database designs. The response JSON structures use nested properties like `_embedded`, `_links`, and unique platform UUIDs.

- **Who uses it:** The PingOne Admin UI console, custom in-house software tools, and provisioning setups.

2. The SCIM 2.0 API (.../scim/v2/.../Schemas)

- **What it is:** An implementation of an open, international industry standard (System for Cross-domain Identity Management - RFC 7643/7644).
- **The Response:** It strictly strips out vendor-specific language and formats everything into clean, standardized SCIM JSON arrays using industry-wide schemas (like the literal `urn:ietf:params:scim:schemas:core:2.0:User` block).
- **Who uses it:** Standard enterprise compliance software like SailPoint, Okta, or Microsoft Entra ID.

PingOne has

🔗 **The Core Directory:** It securely stores active workforce and customer identity profiles, credentials, and group memberships.

🔗 **The Access Engine:** It handles single sign-on (SSO) portals, multi-factor authentication (MFA) prompts, federation protocols (OIDC, SAML), and dynamic access token distribution.

An integration between Identity Governance and Administration (IGA) platform (SailPoint) and Identity Provider (IdP) and directory engine (PingOne) is required to address following use cases

Use Case A: Birthright Provisioning (The Joiner)

- **Scenario:** A new software engineer is hired in the HR system.
- **Action:** SailPoint aggregates the HR file, detects the engineering job code, and automatically sends a POST request to PingOne's /Users endpoint.
- **Result:** The engineer is immediately created in the PingOne directory, mapped to the correct base Population, and can instantly log into the company SSO portal on day one.

Use Case B: Dynamic Access Changes (The Mover)

- **Scenario:** An employee transitions from Marketing to Finance.

- **Action:** SailPoint processes the role change and fires a PATCH request to PingOne to update their department attribute to "Finance" and dynamically swap their associated security group references.
- **Result:** The user immediately loses access to Marketing tools and gains access to the Finance dashboard via PingOne SSO.

Use Case C: Instant Offboarding (The Leaver)

- **Scenario:** An employee is terminated or leaves the company.
- **Action:** SailPoint triggers an immediate high-priority PATCH to PingOne, updating the attribute "active": false.
- **Result:** The user's status shifts to SUSPENDED instantly. All active PingOne SSO sessions are revoked, completely locking them out of corporate resources globally in seconds.

Use Case D: Periodic Access Certification (Audit & Compliance)

- **Scenario:** Security auditors require a quarterly review of who has "Domain Admin" access.
- **Action:** SailPoint pulls a list of all users and their group memberships from PingOne's SCIM /Users and /Groups endpoints.
- **Result:** SailPoint generates a clean dashboard for managers to approve or revoke access, keeping the enterprise legally and structurally compliant.

QnA and Notes

1. Are Users and Groups part of a predefined contract?

Yes, absolutely. Under **RFC 7643**, they are the core standard contract. In SCIM terminology, they are defined as:

- **Predefined Resource Types:** "User" and "Group" are the default, out-of-the-box Resource Types.
- **Core Schemas:** They map to strict, standard schemas identified by unique, globally recognized URNs (Uniform Resource Names):
 - **User Schema:** urn:ietf:params:scim:schemas:core:2.0:User
 - **Group Schema:** urn:ietf:params:scim:schemas:core:2.0:Group

Because they are predefined, any SCIM-compliant identity provider (like Okta, Microsoft Entra, or Ping Identity) and any service provider (your application) already know exactly what attributes to expect inside them (e.g., `userName`, `emails` for Users; `displayName`, `members` for Groups).

2. Are there other objects?

Yes! While Users and Groups are the stars of the show, the SCIM specification defines several other structural and metadata objects:

A. Predefined Out-of-the-Box Resource Extensions

- **Enterprise User Extension**
(`urn:ietf:params:scim:schemas:extension:enterprise:2.0:User`):

While not a standalone object, this is a predefined *extension schema* defined in RFC 7643. It extends the core User object to cleanly house corporate attributes like `employeeNumber`, `costCenter`, `organization`, `division`, `department`, and `manager`.

B. Standard Discovery / Metadata Objects

To keep SCIM dynamic and highly inspectable, RFC 7643 defines three predefined metadata resources:

- **ServiceProviderConfig:** Represents the configuration and supported features of your SCIM API (e.g., does your server support PATCH, bulk requests, or sorting?).
- **ResourceType:** Represents the list of resources your server actually implements (e.g., it tells a client, "I support Users and Groups").
- **Schema:** Represents the structural blueprint of all fields, data types, and mutability rules of your data.

C. Custom Schema Objects

SCIM is extensible. If your system needs objects like "**Roles**", "**Entitlements**", "**Devices**", or "**Tenants**", you are fully allowed to create your own custom schemas and map them to custom endpoints (e.g., /Entitlements) using custom URN namespaces.

3. How to explain these objects in "SCIM Terms"

If you are explaining SCIM in an architectural review or technical documentation, avoid generic software development terms like "database tables" or "JSON payloads." Instead, use the **formal hierarchical terms defined in RFC 7643 (Section 2)**:

The Terminology Hierarchy

- **Resource:** The common denominator. An individual instance of an identity object (e.g., *a specific user named Jane Doe*). All SCIM objects are derived from this base and inherit standard metadata like id, externalId, and meta.
- **Schema:** The strict structural data blueprint. It dictates the valid attributes, their data types (String, Boolean, etc.), and behaviors (readOnly, writeOnly). Identifiable by a unique URN.
- **Resource Type:** The mapping concept. It links a specific endpoint path (e.g., /Users) to a main Core Schema, plus any allowed extension schemas.

Example of how to structure your explanation:

"In SCIM architecture, we do not simply exchange arbitrary JSON documents. We exchange standardized **Resources**.

A **Resource** is an instance of a **Resource Type** (such as User or Group), which is mapped to a highly predictable, IETF-defined **Core Schema**.

- The **User Resource Type** maps to the Core User Schema (urn:ietf:params:scim:schemas:core:2.0:User).
- The **Group Resource Type** maps to the Core Group Schema (urn:ietf:params:scim:schemas:core:2.0:Group).
- If custom objects or industry-specific properties (like corporate manager hierarchies or application roles) are required, we do not modify the core schemas. Instead, we implement **Schema Extensions** (such as the predefined EnterpriseUser schema) to safely expand the contract without breaking standard protocol compatibility."